SAMUEL BERRIOS, JR.

PROFILE

- Cybersecurity program and project leader, currently serving as acting Vulnerability Management Lead, with proven track record in advancing confidentiality, integrity, availability, authenticity, and nonrepudiation of corporate technology footprint through leading enterprise-wide initiatives that mitigate systemic information security risk while enhancing on-prem endpoint, network & cloud resilience.
- Proficient in vulnerability management, web application & cloud security testing, incident response & recovery, cyber threat intelligence, agentic automation, and counter-UAS (C-UAS) threat detection and mitigation.
- Reengineer core cybersecurity, technology, and data processes through baselining current-state architecture, redefining, redesigning, and realigning fundamental domain workflows and protocols to streamline technical operations, accelerate digital transformation, and fortify security posture.
- Translate multifaceted internal and external data and AI-driven analytics into clear, actionable insights that drive informed decision-making and sound policy outcomes.
- Engage diverse stakeholders at every organizational level to navigate unforeseen challenges, surface emergent opportunities, and simplify systemic complexity to transform mission-critical information security initiatives into quantifiable, sustainable, lasting strategic impact.

EDUCATION

2004 **University of Texas at San Antonio Carlos Alvarez College of Business** (San Antonio, TX)
University of Texas System Online Consortium Master of Business Administration

2001 **University of Texas at San Antonio Carlos Alvarez College of Business** (San Antonio, TX)
Bachelor of Business Administration, Accounting
Bachelor of Business Administration, Finance

2000 **University of Texas at San Antonio Carlos Alvarez College of Business** (San Antonio, TX)
Bachelor of Business Administration, Management, International Business Concentration

Leadership: Founding President, Undergraduate Business Student Council (BSC); Founding President, Phi Chi Theta National Co-ed Business and Economics Fraternity, Epsilon Omega Chapter; Founding Member, Delta Sigma Phi Social Fraternity, Theta Phi Chapter

Honors: Beta Alpha Psi International Honor Organization for Financial Information Students and Professionals; Mortar Board National College Senior Honor Society; Omicron Delta Epsilon International Honor Society in Economics; Omicron Delta Kappa National Leadership Honor Society

PROFESSIONAL CERTIFICATIONS & TRAINING

2024 CompTIA: Security+ Certification
2018 Project Management Institute (PMI): Project Management Professional (PMP) Certification
2026 Department of War (DoW) Cybersecurity Workforce Certification Training (CWCT): Machine Learning Foundations for Cybersecurity (*Expected Completion – Dec 2026*)
2026 DoW CWCT: Introduction to Artificial Intelligence for Cybersecurity
2026 DoW CWCT: Python Institute Certified Associate Python Programmer (PCAP) Exam Prep
2026 CISA Federal Cyber Defense Skilling Academy Pathway: Incident Response
2025 CISA Federal Cyber Defense Skilling Academy Pathway: Vulnerability Analysis

2025 CISA: Enterprise Cyber Threat Analysis and Response
2024 CISA Federal Cyber Defense Skilling Academy Pathway: Defensive Cybersecurity
2022 Mandiant (now Google Cloud): Cyber Security Policy and Implementation
2022 Mandiant (now Google Cloud): Cyber Intelligence Foundations
2022 CISA: Cyber Supply Chain Risk Management

AREAS OF EXPERTISE

- Vulnerability & Continuous Threat Exposure Management
- Information Technology Program, Project, Product & Process Portfolio Management
- Cybersecurity Threat & Predictive Vulnerability Intelligence
- Cybersecurity Asset & External Attack Surface Management
- Information Security Strategy & Policy Management
- Intelligent Process & Agentic Automation
- Penetration Testing
- Cybersecurity Incident & Breach Management
- Cybersecurity, Applied Artificial Intelligence & Data Analytics

PROFESSIONAL APPOINTMENTS

Consumer Financial Protection Bureau (CFPB) (Washington, DC) Jan 2017 to Present
Cybersecurity Operations Specialist (Acting Vulnerability Management Lead/ Security Program & Project Manager and Product Owner) *Jul 2022 to Present*
Acting Vulnerability Management Lead and product owner for Qualys and Axonius, leading corporate IT security programs and projects for the Chief Information Security Officer (CISO) Cybersecurity Operations (CyberOps) division to strengthen enterprise cybersecurity posture, reduce hybrid IT environment vulnerabilities, and reinforce on-prem endpoint, network, and cloud resilience. Hold Position of Public Trust (PPT).

- Mitigate corporate cyber risk through continuous threat exposure management (CTEM) framework, managing attack surface by scoping and discovering agency digital infrastructure exposures via network & cloud vulnerability scanning (Qualys and Google Wiz) and endpoint visibility (CrowdStrike), cyber asset attack surface management (CAASM) for unified asset inventory and coverage-gap detection (Axonius), externally disclosing vulnerabilities via crowdsourced reconnaissance (Bugcrowd), prioritizing findings by exploitability, impact, and attack vector using predictive vulnerability intelligence and cyber threat intelligence (Anomali ThreatStream) to forecast likely exploitation ahead of attacker activity, standard frameworks (MITRE ATT&CK/CAPEC, CVE/CWE, FIRST CVSS/EPSS, CISA KEV), and structured decision models (CISA SSVC, FAIR), validating results by hosting annual cross-agency tabletop exercises and external penetration testing (contracted vendors) and mobilizing remediation teams to close findings (patching, software updates, configuration changes) through ServiceNow.
- Own the Qualys product backlog and vulnerability reporting, producing weekly cybersecurity reports for operations and technology leadership and bi-weekly delayed-patch reports to system owners.
- Run the Known Exploited Vulnerabilities (KEV) response process with daily checks and notifications issued within one business day, escalating delayed high-priority patches for tracking.
- Govern the patching exception process, reviewing requests and documenting approvals within five business days.

- Manage the external attack surface through the CISA Cyber Hygiene program (targeting over 90% coverage of known internet-facing assets) and the Bugcrowd vulnerability disclosure program, with initial response to reports within three business days.
- Lead cross-functional IT security teams on Agile/SDLC cyber technology implementation, coordination, management, and oversight projects for CyberOps that further augment the corporate enterprise IT landscape security posture, including oversight of external independent penetration testing engagements (Carnegie Mellon University (CMU) Software Engineering Institute (SEI) DevSecOps Software Assurance Capability Assessment, a social media penetration test coordinating contractor Rules of Engagement, and a penetration test of non-domain-joined devices) from scoping through remediation to identify attack vectors and drive risk mitigation; manage the Department of Justice (DOJ) Security Operations Center-as-a-Service (SOCaaS) project from interconnection testing of the DOJ and CFPB Splunk systems through Authorization to Operate (ATO), Full Operating Capability, and the FY25 Memorandum of Agreement (MOA) renewal, supporting defensive filtering, enterprise security monitoring, and Zero Trust Architecture implementation; support project management of the Cribl rollout through T&I governance, delivering cost savings and operational efficiencies; and drive Jira adoption to track CyberOps projects and system-owner activities.
- Spearhead development and lifecycle management of cybersecurity governance playbooks (e.g., incident response and recovery and vulnerability management), including updates to the Incident Response and Recovery policy and plan and the CSIRT SOP, a new Acceptable Use Policy (AUP) Standard Operating Guide, and a Master Index of CyberOps Procedures and Documentation, driving standardization and compliance with federal and agency IT security requirements.
- Develop policy-driven recommendation, information, and briefing memos for senior IT executives, including policy memos on data loss prevention, social media blocking, web conferencing, and decommissioning procedures, quick-turn cyber and threat info papers, and Cybersecurity's input to the weekly CIO briefing book, synthesizing federal IT security policies and program updates to support strategic decision-making, situational awareness, and endorsements.
- Coordinate CyberOps responses to CISA Emergency Directives, CyberScope data calls, and CISA and OMB data calls, supporting CFPB's real-time threat response.
- Support management of Office of Inspector General (OIG) corrective action plans (CAPs) for CyberOps, including closing the recommendation on CFPB's ransomware strategy by co-authoring the Cyber Incident Response and Recovery Plan update, contributing to the team's Level 4 OIG maturity rating.
- Serve as Contracting Officer's Representative (COR) for cybersecurity software and cloud service contracts including Axonius, Cribl, and Splunk, completing all FY24 option-year renewals without service interruption and passing a COR file audit; serve as Alternate COR (ACOR) for the CyberOps Blanket Purchase Agreement (BPA) Task Order and as ACOR and project manager for the SEI Independent Cloud Security Assessment, coordinating scheduling, stakeholder sessions, technical artifacts, and status updates; onboard a contractor to execute a Bureau-wide incident response exercise supporting most CFPB authorized systems; and support the cyber procurement process through market research, task order support justification, and technical proposal evaluation (including as an alternate Technical Evaluation Panel member for the Cyber BPA Task Order solicitation), directly interfacing with contractors to monitor and enforce compliance with contract terms, deliverables, and cybersecurity requirements including Federal Risk and Authorization Management Program (FedRAMP).

- Support cyber financial management process through formulating software license contract obligations, tracking expenditures against allocated funding, and monitoring spend plans and balances throughout the fiscal year to ensure funding actions align with task order requirements and timelines, contributing to FY26 budget preparation, FY25 spending reviews, BPA task order restructuring, and the T&I Spend Action Tracker, and helping restructure the Splunk license contract to reduce estimated annual license costs by $411,000 with additional AWS savings.
- Manage the CyberOps SharePoint site, including SharePoint Online migration preparation, content tagging and organization, and the build of the CyberOps Internal SharePoint Library, establishing it as the centralized hub for cybersecurity knowledge management and streamlining team access to operational and technical resources.

Management and Program Analyst *Jan 2017 to Jun 2022*

Supported Supervision, Enforcement and Fair Lending (SEFL) leadership across multiple program, project and process management roles, leading cross-functional projects that improved operational efficiency and organizational performance. Held Position of Public Trust (PPT).

- SEFL Front Office (FO) | Feb 2021 to Jun 2022
- Managed the internal review and release of SEFL-authored public-facing documents, safeguarding the consistency, accuracy, and transparency of Bureau messaging.
- Documented the SEFL clearance process (Clearance Inbox and Book Inbox workflows) and presented best practices to automate it: auto-forwarding clearance requests to Clearance Group members through a backend server rule built and tested with the Technology & Innovation (T&I) Enterprise Platform team, MS Outlook rules routing eCRM and Executive Secretariat emails to the SEFL Book Inbox, and a proposed SharePoint redesign to replace email and the Word-based Book Tracker with centralized upload, storage, and retrieval.
- Office of Supervision Examinations (OSE) Headquarters Management and Strategy Team (MST), supporting the Systems and Registration Team (SRT) | Feb 2019 to Feb 2021
- Ran recurring access validations for the supervision examination system (SES, Salesforce): quarterly user access reviews, semi-annual permission-based role audits, and a Q Drive access audit. Built the audit workbooks, collected confirmations from offices, compared samples against Technology & Innovation (T&I) access lists, and sent results to leadership and T&I for access changes, supporting closure of Federal Reserve Office of Inspector General findings.
- Developed and maintained the SES user access review and systems permissions procedures through clearance and posting, and revised the confidential supervisory information (CSI) storage SOP and SEFL directives on SES access and compliance tool access for substance and style.
- Managed Extranet operations, reviewing and approving external access requests and filing work orders to set up entities, modify Q Drive folders, and remove former users.
- Maintained the Systems Roadmap and Task Planner (MS Access) databases weekly, using a documented process to compact the back end, export data, and publish updated Tableau reports to the server, and provided project management and analytical support for OSE systems projects, including the HMDA Supervision Tool 2.0 (revising training materials for the new version), the Compliance Tool, and the SES.
- Maintained the OSE budget dashboard in Tableau, extracting data from Chief Financial Officer (CFO) deliverables, transforming it in a financial calculation's workbook, loading it, and troubleshooting discrepancies, and helped set up the spreadsheets to track and analyze OSE headquarters external training expenditures.
- Served as OSE's liaison to T&I during the Office 365 migration, coordinating announcements, training, champions lists, and SharePoint approver and folder-access checks.

- Led development of the OSE Field Employee Emergency Guide, interviewing regions on best practices, incorporating feedback from the Office of Security, Legal, and other Bureau offices, and preparing the Regional Administrative Officer presentation.
- Maintained the SOP Refresh matrix and plan, reviewed SOPs from other staff, and ensured approved SOPs were posted to the Bureau repository.
- Produced OSE's mandatory training compliance reports from Learning Management System data, and wrote the February 2021 transition plan covering 13 workstreams, with SOPs, process packages, and access transfers.
- Served as Contracting Officer's Representative (COR) for the OSE Language Services contract, managing contractor quotes, deliverable tracking in a database, IPP invoice approval, and funding forecasts, and escalating a funding shortfall to leadership to place the contract on hold.

■ Office of Fair Lending and Equal Opportunity (OFLEO) FO | Jan 2017 to Jan 2019

- Defined business requirements and the business case for the Home Mortgage Disclosure Act (HMDA) Validation Tool, prioritized Redlining Risk Assessment Mapper (RRAM) issues with T&I and supported the RRAM rollout and regional training, helped establish the Enforcement Action Plan memo database in MS Access as the system of record, and built an MS Project dashboard, Visio process maps, and an office organization chart, and supported the Box closeout and SES migration reporting testing.
- Supported Fair Lending Front Office operations by maintaining the Front Office responsibilities matrix and policy team tracker and developing the project timeline and checklist for the Credit Deserts conference.
- Led records management as the office Records Liaison, correcting the records schedule and integrating it with Capstone, and supported the office relocation and Fair Lending reorganization, including a shared-folder distribution plan for the Deputies.
- Developed strategic budget proposals and mid-year adjustments, tracked expenditures, and delivered monthly spend reporting to office leadership.
- Served as Level I COR, earning certification in 2017 and developing independent government cost estimates, performance work statements, and task orders for office contracts, including court reporting services, in compliance with FAR and Bureau acquisition policy; developed procurement proposals and administered purchase-card expenditures as needed.

Integrated Systems, Inc. (ISI) (Washington, DC) *2016*

Business Process Reengineering Analyst (Contractor)

Supported the Securities and Exchange Commission's (SEC) Office of Information Technology (OIT) SDLC transformation from current to future state, serving as team process SME for business process maps and narratives.

- Developed a training platform in Adobe Captivate to help project managers navigate the new SDLC process.
- Created UML-based use case models to support requirements development for a new SDLC software automation tool.
- Evaluated and overhauled process narrative actors and activities to deploy new and existing SDLC narratives and maps using Visio.
- Ensured compliance with enterprise architecture directives by translating the future-state SDLC process map into BPMN 2.0 standards using Visio.
- Established prototype SDLC SharePoint site to centralize process documentation using SharePoint Designer.

Cognizant Technology Services (Arlington, VA) *2015*

Consultant (Contractor)

Reinforced Assurant's procedural compliance by analyzing, documenting, revising, and deploying internal controls process narratives and maps.

- Facilitated virtual sessions with stakeholders to research, analyze, and revise process narratives and maps (actors, activities, systems, controls) for financial and operational current-state processes using Visio.
- Observed and documented on-site "As-Is" mobile device restoration and disposition processes, ensuring full process transparency.

Cigna (Arlington, VA) *2014 to 2015*

Business Process Engineer (Contractor)

Supported migration to and integration of a future-state ERP healthcare insurance system from disparate legacy systems by evaluating, developing, and deploying system process flows and change impact evaluations.

- Facilitated virtual sessions with stakeholders to model and deploy "As-Is" and "To-Be" process maps for product, benefit, and client configuration using modified BPMN 2.0 and BlueWorks Live, driving business requirements alignment and establishing the level of effort for requirements architecture.
- Analyzed and decomposed business requirements into business rules to support IT system-action determination.

MissionSquare Retirement (f/k/a ICMA-RC) (Washington, DC) *2013*

Analyst (Contractor)

Enhanced the IT group's operational efficiency, serving as an internal process thought leader in researching best practices and developing, deploying, and maintaining policy, standard, and procedural artifacts across the IT domain.

- Led client-facing discussions with process owners to develop and deploy user-friendly work process guidelines and templates, standardizing IT enterprise capture of SDLC business, technical, and non-technical requirements.
- Deployed existing group policies, standards, and procedures into new documentation framework.

Deloitte Consulting LLP (Alexandria, VA) *2012 to 2013*

Business Process Reengineering Analyst (Contractor)

Supported enterprise-wide implementation of the Naval Justice Information System (NJIS), a case-management and workflow-tracking platform for Department of the Navy (DON) Program Executive Office for Enterprise Information Systems (PEO-EIS) Sea Warrior Program (PMW 240). Held Secret Clearance.

- Designed and deployed enterprise-wide "As-Is" and "To-Be" business process maps in BPMN 2.0 using iGrafx, defining current- and future-state process data inputs and outputs.
- Conducted gap analysis of data transferred across naval law enforcement communities to ensure compliance with congressionally mandated reporting requirements.
- Facilitated client-facing working sessions with process owners and stakeholders to assess change impacts and identify information-transfer gaps across actors, activities, systems, and workflows.

Leidos (f/k/a Science Applications International Corporation (SAIC)) (McLean, VA) *2011 to 2012*

Senior Business Process Analyst

Supported the Department of State (DOS) Bureau of Information Resource Management (IRM) Vanguard 2.2.1 transformation from current to future state through the streamlining and consolidation of numerous IT processes. Held Secret Clearance.

- Reduced performance management data collection cycle time by leveraging a new SharePoint-based tool that automated collection and centralized data storage.
- Monitored subcontractor compliance against monthly contract financial and nonfinancial performance goals, ensuring receipt of the maximum contractual incentive revenue.
- Standardized project process improvement operations by authoring business process templates.

Booz Allen Hamilton (BAH) (McLean, VA) *2010 to 2011*

Senior Consultant

Supported the Department of the Air Force (DAF) A7C Civil Engineer transformation from current to future state through development, maintenance, and deployment of business process maps and narratives. Held Secret Clearance.

- Managed all IT-related activities between the process project teams and IT.
- Constructed, deployed, and revised "As-Is" business process maps in Visio synthesizing interlinked actors, activities, and information to determine capability requirements for a military base housing management IT system.
- Developed and maintained online business process guidebooks and maps in Visio, providing the client with standardized, centrally located operating procedures.

Federal Energy Regulatory Commission (FERC) (Washington, DC) 2002 to 2010

Energy Industry Analyst *2005 to 2010*

Enforced regulatory compliance with financial and operational filing requirements through oversight of a 200-entity oil pipeline and centralized service company portfolio. Held Position of Public Trust (PPT).

- Led design, end-user testing, and deployment of submission software using an SDLC framework, reducing filing costs by a projected 10%.
- Collaborated in real time with an oil pipeline trade association to ensure proper dissemination of regulatory developments and conveyed association feedback to Commission senior staff.
- Validated and analyzed submitted financial, operational, and transactional data using SQL, Access, and Excel.

Organizational Process Consultant (Detailee) *2004 to 2005*

Achieved conformity with the Paperwork Reduction Act (PRA) of 1995 by revamping agency-wide current-state information assessment processes and restructuring existing reporting requirements. Held Position of Public Trust (PPT).

- Interfaced with federal agencies to formulate best practices for institutionalizing an agency-wide organizational model and processes for assessing current and future information requirements.
- Appraised current-state information requirements through gap analysis, interfacing with internal and external stakeholders to evaluate the effectiveness of collected data and the efficiency of "As-Is" collection and disposition processes.
- Baselined and mapped core processes in Visio; delivered "To-Be" organizational design and process options in PowerPoint; defined roles and responsibilities for key positions; and deployed an implementation plan to transition the agency from current to future state.

Public Affairs Specialist (Detailee) *2003 to 2004*

Redesigned Commission website and resolved public inquiries in a timely manner. Held Position of Public Trust (PPT).

- Developed content across multiple areas to ensure easy access to information.
- Interfaced with internal stakeholders to raise project awareness and solicit input on site design and content.
- Benchmarked best practices to improve website usability and visibility.

- Responded to ~50 public inquiries daily via email and phone, assisting external users in accessing Commission-related information.

Accounting Policy Analyst *2002 to 2003*

Researched and assessed accounting issues affecting energy companies, recommending courses of action to anticipate industry direction and practices. Held Position of Public Trust (PPT).

- Evaluated proposed certificates of public convenience for energy companies seeking to construct US natural gas terminals and pipelines, analyzing financial statements.
- Advised energy companies on Commission accounting regulations.
- Developed and delivered training on the potential impact of Sarbanes-Oxley legislation shortly after its introduction.

MILITARY SERVICE

United States Army (USA) - Active Duty (Various Locations) *1992 to 1996*

Weapons Locating Radar Operator, Military Occupational Specialty (MOS) 13R - Specialist (E-4), Honorable Discharge

Operated real-time detection and tracking systems to identify, characterize, and report hostile threats under high-stakes operational conditions, directly paralleling the detect-analyze-respond discipline now applied to enterprise cyber threat intelligence, vulnerability management, and incident response processes, as well as the detection, tracking, and threat-mitigation principles central to counter-UAS (C-UAS) operations. Held Secret Clearance.

- ✪ Determined point of origin and impact of incoming rounds, transmitting accurate targeting data to friendly artillery units and strengthening base security.
- ✪ Performed maintenance on radar and associated equipment.
- ♉ Awarded Army Commendation Medal, Army Achievement Medal, Army Good Conduct Medal, and National Defense Service Medal.
- ♉ Grafenwoehr Army Post Soldier of the Month for October 1993.

SCOUTING & YOUTH LEADERSHIP

Scouting America (f/k/a Boy Scouts of America (BSA)) - Troop 162 (Wright-Patterson Air Force Base (WPAFB))

1991 Eagle Scout

- ✯ Eagle Scout project was the creation and installation of markers for the Wright Brothers Historical Walking Trail at WPAFB. Further information is available here.

HOBBIES & INTERESTS

Recreational Drone Pilot · Golfing · Photography

PLATFORMS & TECHNOLOGY STACK

Security Tools & Technologies

- **Vulnerability, Attack Surface & Threat Exposure Tools**: Qualys & Google Wiz (Scoping/Discovery – Vulnerability Management & Attack Surface Management (ASM)), Axonius (Scoping/Discovery – Cyber Asset Attack Surface Management (CAASM) & Asset Inventory), OpenVAS (Discovery – Vulnerability Management), Anomali ThreatStream (Prioritization – Threat & Predictive Vulnerability Intelligence), urlscan.io (Validation – URL/Phishing Analysis)
- **Penetration Testing**: Kali Linux, Bugcrowd (CTEM Discovery/Validation – External Vulnerability Disclosure), Burp Suite (CTEM Discovery/Validation – Internal Pen Testing), Metasploit, OWASP ZAP, SQLMap, Hashcat, Hydra, Recon-ng, Aircrack-ng, NetExec, Netcat
- **Breach & Attack Simulation (BAS):** Atomic Red Team (Technique Testing – MITRE ATT&CK-Mapped Adversary Emulation)
- **Incident Response& Security Monitoring**: Splunk (Incident Response - Security Information and Event Management (SIEM)/Security Orchestration, Automation, and Response (SOAR)), Cribl (Data Pipeline), Shuffle (Orchestration – Automated Incident Response Playbooks & Alert Enrichment)
- **Endpoint & Host-Based Detection**: CrowdStrike Falcon (Detection - Endpoint Detection and Response (EDR) & CTEM Discovery/Validation – Endpoint Visibility), Wazuh (Detection – SIEM/Extended Detection and Response (XDR) & Host-Based Intrusion Detection)
- **Network Traffic Analysis & Defense Tools**: Wireshark, Nmap/Zenmap, Snort, pfSense (Firewall/Network Security)
- **Cryptography & Encoding Tools**: OpenSSL, CyberChef
- **Deception Technology & Honeypots**: T-Pot, Canarytokens

AI, Automation, Development & Cloud

- **AI & Process Automation**: Claude, Microsoft Power Automate, n8n, LangChain
- **Languages & Scripting**: Python, SQL, PowerShell, Visual Basic for Applications (VBA)
- **Development Environments & Version Control**: Visual Studio Code, Visual Studio, Jupyter Notebook, Google Colab, Git, GitHub
- **Cloud & Containerization**: Amazon Web Services (AWS), Docker, Kubernetes

Business & Enterprise Systems

- **IT Service Management (ITSM)**: ServiceNow (CTEM Mobilization – Remediation Tracking)
- **Project Management**: Jira, Microsoft Project
- **Business Process Management (BPM) & Process Mapping**: Microsoft Visio, IBM BlueWorks Live, iGrafx
- **Data Analytics & Business Intelligence (BI):** Tableau, Microsoft Excel
- **Collaboration & Knowledge Management**: Microsoft SharePoint
- **Customer Relationship Management (CRM):** Salesforce (Case Management System)
- **Human Capital Management (HCM):** SAP SuccessFactors
- **Experience Management (XM):** Qualtrics

TECHNICAL & REGULATORY FRAMEWORKS

AI Governance

- **AI Risk Management Frameworks, Standards & International Regulation**: NIST AI Risk Management Framework (AI RMF), International Organization for Standardization/International Electrotechnical Commission (ISO/IEC) 42001 Artificial Intelligence Management System (AIMS), EU AI Act (as Amended by the Digital Omnibus on AI, Regulation (EU) 2026/1744, July 2026)
- **Federal AI Law, Executive Orders & National Security Policy**: AI in Government Act of 2020 (P.L. 116-260, Div. U), Advancing American AI Act (P.L. 117-263), EO 13960 (Promoting the Use of Trustworthy AI in the Federal Government), EO 14179 (Removing Barriers to American Leadership in AI), OMB Memorandum M-25-21 (Accelerating Federal Use of AI Through Innovation, Governance, and Public Trust), OMB Memorandum M-25-22 (Driving Efficient Acquisition of AI in Government), EO 14409 (Promoting Advanced AI Innovation and Security), National Security Presidential Memorandum-11 (NSPM-11, Artificial Intelligence in the National Security Enterprise)
- **AI Security & Threat Frameworks**: MITRE Adversarial Threat Landscape for Artificial-Intelligence Systems (ATLAS), Open Worldwide Application Security Project (OWASP) Top 10 for Large Language Model (LLM) Applications, NIST IR 8596 (Cybersecurity Framework Profile for Artificial Intelligence (Cyber AI Profile); Draft)
- **Agentic & Autonomous AI Governance**: NIST-AI-600-1 (NIST AI RMF Generative AI Profile), OWASP Multi-Agentic System (MAS) Threat Modeling Guide, MITRE ATLAS Agentic AI Case Studies, Model Context Protocol (MCP) and Agent2Agent (A2A) Protocol Security Considerations, NIST SP 800-53 SR/SA (Control Tailoring of AI Agent Tool-Access and Least-Privilege Enforcement), OMB M-25-21 (Agency Human-Oversight and Accountability Requirements for Autonomous AI Use Cases, Human-in-the-Loop/Human-on-the-Loop Control Design of Consequential Automated Decisions)
- **AI Incident Readiness & Response (Frontier AI Training & Evaluation):** NIST CAISSI/NSA SISC/CISA Key Practices for Incident Readiness and Response in Super Intelligence Training and Evaluation (Joint Cybersecurity Information PP-26-4396, Ver 1.0, October 2026; Voluntary, TLP:CLEAR) (Ten Practices Across Prepare, Detect, Respond, Recover, and Report Stages, Mapped to NIST CSF 2.0 and NIST SP 800-61 Rev. 3

Governance, Risk & Compliance

- **Risk Management & Authorization:** NIST Cybersecurity Framework (CSF) 2.0, NIST SP 800-37 (RMF), NIST SP 800-30 (Risk Assessment), NIST SP 800-39 (Risk Management), NIST Federal Information Processing Standard (FIPS) 199 (Standards for Security Categorization of Federal Information and Information Systems), NIST FIPS 200 (Minimum Security Requirements for Federal Information and Information Systems)
- **Security Controls & Assessment:** NIST SP 800-53 Rev. 5 (Incl. IA and SA/SR Control Families), NIST SP 800-53A (Assessment Procedures), NIST SP 800-128 (Security-Focused Configuration Management), Center for Internet Security (CIS) Critical Security Controls (CIS 18, V8.1)
- **Federal & Industry Regulatory**: US Federal Information Security Management Act (FISMA), System and Organization Controls (SOC) 2 (Type I/II), Payment Card Industry Data Security Standard (PCI DSS)
- **Federal Executive & National Security Policy**: EO 14390 (Combating Cybercrime, Fraud, and Predatory Schemes Against American Citizens), EO 14306 (Sustaining Select Efforts to Strengthen the Nation's Cybersecurity), EO 14028 (Improving the Nation’s Cybersecurity), National Security

Memorandum-22 (NSM-22, Critical Infrastructure Security and Resilience), National Security Presidential Memorandum-12 (NSPM-12, Cybersecurity of National Security Systems)

- **CISA Binding & Emergency Directives**: BOD 26-04 (Prioritizing Security Updates Based on Risk), BOD 26-02 (Mitigating Risk from End-of-Support Edge Devices), BOD 25-01 (Implementing Secure Practices for Cloud Services), BOD 23-01 (Implementation Guidance for Improving Asset Visibility and Vulnerability Detection on Federal Networks), BOD 20-01 (Develop and Publish a Vulnerability Disclosure Policy), CISA Emergency Directives (ED)
- **Governance, Audit & Service Management**: ISO/IEC 27001 (Information Security, Cybersecurity and Privacy Protection - Information Security Management Systems - Requirements)/27002 (Information Security Controls), ISO/IEC 20000 (IT Service Management), Information Systems Audit and Control Association (ISACA) Control Objectives for Information and Related Technologies (COBIT), Committee of Sponsoring Organizations of the Treadway Commission (COSO) Internal Control-Integrated Framework
- **CUI, Defense & Contractor Compliance**: NIST SP 800-171 Rev. 2 (DOD Assessment Baseline; Rev. 3 Current NIST Release) (Protecting Controlled Unclassified Information (CUI) in Nonfederal Systems and Organizations), NIST SP 800-171A, Cybersecurity Maturity Model Certification (CMMC) 2.0 (32 CFR Part 170; 48 CFR Acquisition Rule), Defense Federal Acquisition Regulation Supplement (DFARS) 252.204-7012/252.204-7021, Federal Acquisition Regulation (FAR) (Supply Chain and Acquisition Requirements)
- **Workforce & Reference Architectures**: NIST SP 800-181 Rev. 1 (NICE Workforce Framework of Cybersecurity), NIST SP 1800-5 (IT Asset Management), NIST SP 1800-27 (Securing Property Management Systems)
- **Federal Data Policy & Evidence Act Governance**: OMB M-25-05 (Phase 2 Implementation of the Foundations of Evidence-Based Policymaking Act: Open Government Data Access and Management Guidance), OMB M-19-18 (Federal Data Strategy), OMB M-19-23 (Evidence Act Phase 1 Implementation), OMB Circular A-130 (Managing Information as a Strategic Resource)
- **Data Management & Data Quality Standards:** ISO/IEC 11179 (Metadata Registries), Data Management Association (DAMA)-Data Management Body of Knowledge (DMBOK), ISO 8000 (Data Quality)
- **Privacy & Data Protection**: NIST Privacy Framework, Privacy Act of 1974, E-Government Act of 2002 (Privacy Impact Assessments), Health Insurance Portability and Accountability Act (HIPAA) Security Rule (Health Data Security), Gramm-Leach-Bliley Act (GLBA)/Federal Trade Commission (FTC) Safeguards Rule (Financial Data Security), CFPB Consumer Financial Protection Circular 2022-04 (Insufficient Data Protection or Security of Sensitive Consumer Information), Family Educational Rights and Privacy Act (FERPA) and Children's Online Privacy Protection Act (COPPA)
- **Privacy Management Standards & International Data Protection**: ISO/IEC 27701:2025 (Privacy Information Management System (PIMS)), EU General Data Protection Regulation (GDPR), EU-US Data Privacy Framework (DPF)
- **Records & Information Management**: Paperwork Reduction Act (PRA) of 1995, Federal Records Act, National Archives and Records Administration (NARA) Records Schedules and Retention Requirements, Freedom of Information Act (FOIA)

Security Operations

- **Vulnerability & Continuous Threat Exposure Management (CTEM)**: Gartner CTEM Framework (Scoping, Discovery – Attack Surface Management (ASM), Prioritization – Predictive Vulnerability Intelligence, Validation, Mobilization), Breach and Attack Simulation (BAS)
- **Vulnerability Enumeration, Scoring & Risk Prioritization**: MITRE Common Vulnerabilities and Exposures/Common Weakness Enumeration (CVE/CWE), NIST National Vulnerability Database (NVD), Forum of Incident Response and Security Teams (FIRST) Common Vulnerability Scoring System (CVSS) V4, FIRST Exploit Prediction Scoring System (EPSS), CISA Stakeholder-Specific Vulnerability Categorization (SSVC), CISA Known Exploited Vulnerabilities (KEV) Catalog, OWASP Risk Rating Methodology, Factor Analysis of Information Risk (FAIR)
- **Open-Source & Dark Web Intelligence Authorities (OSINT):** Cybersecurity Information Sharing Act of 2015 (CISA 2015; Expires December 11, 2026 Absent Reauthorization) Liability-Protected Threat Indicator Sharing, National Cybersecurity Protection Act of 2014 (NCCIC Information-Sharing Mandate), Cybersecurity and Infrastructure Security Agency Act of 2018 (CISA Agency Threat-Intel Coordination Authority), NIST SP 800-150 (Guide to Cyber Threat Information Sharing), CFAA 1986 (Legal Boundaries of Dark Web Collection)
- **Open-Source Intelligence Collection & Intrusion Analysis Tradecraft**: US Army Techniques Publication (ATP) 2-22.9 (Open-Source Intelligence) Collection Doctrine, Diamond Model of Intrusion Analysis (Adversary-Capability-Infrastructure-Victim) and MITRE ATT&CK Reconnaissance/Resource Development (Tactics of Adversary Pivoting and Intrusion Analysis), Intelligence Cycle (Direction/Planning-Collection-Processing-Analysis-Dissemination-Feedback) Tradecraft
- **Threat Intelligence Sharing & Handling Standards**: Structured Threat Information Expression/Trusted Automated Exchange of Intelligence Information (STIX/TAXII) Threat Intelligence Sharing, FIRST Traffic Light Protocol (TLP) of Sensitive Intelligence Handling
- **Analytic Sourcing Standards & CTI Program Maturity:** Intelligence Community Directive (ICD) 203/206 Analytic Sourcing and Confidence-Level Tradecraft Standards and Admiralty Code Source-Reliability/Information-Credibility Rating, SANS CTI Maturity Models of Program Benchmarking
- **Adversary Tactics & Attack Modeling:** MITRE Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK), Lockheed Martin Cyber Kill Chain, MITRE Common Attack Pattern Enumeration and Classification (CAPEC)
- **Cyber Deception & Adversary Engagement**: MITRE Engage (Cyber Deception & Adversary Engagement Framework), CISA Using Cyber Decoys to Strengthen Detection and Response Guidance (Tripwires, Breadcrumbs, Honeytokens)
- **Patch & Remediation Management**: NIST SP 800-40 Rev. 4 (Guide to Enterprise Patch Management Planning), NIST SP 1800-31 (Improving Enterprise Patching of General IT Systems)
- **Penetration Testing Methodology & Legal Authorization**: Computer Fraud and Abuse Act (CFAA) of 1986 (Unauthorized-Access Boundaries), NIST SP 800-115 (Technical Guide to Information Security Testing and Assessment), Penetration Testing Execution Standard (PTES), Written Authorization and Rules of Engagement (ROE) (Scope, Targets, Timing, Permitted Techniques, Data Handling, Emergency Contacts), Open Source Security Testing Methodology Manual (OSSTMM) (ISECOM; V3, 2010, Legacy) with Risk Assessment Values (RAV) Metrics, Information Systems Security Assessment Framework (ISSAF; Legacy)
- **Application, Web & Mobile Security Testing**: OWASP Web Security Testing Guide (WSTG), Application Security Verification Standard (ASVS), OWASP API Security Top 10, Mobile

Application Security Verification Standard (MASVS)/Mobile Application Security Testing Guide (MASTG)

- **Compliance-Driven & Cloud Penetration Testing**: FedRAMP Penetration Test Guidance (Annual Testing of Cloud Service Providers), ISO/IEC 27001:2022 Annex A Technical Vulnerability Management and Security Testing Controls, PCI DSS V4.0.1 Requirement 11.4 (Internal/External Penetration Testing At Least Annually and After Significant Change) and PCI Security Standards Council Penetration Testing Guidance, HIPAA Security Rule Technical Evaluation (45 CFR 164.308(a)(8))
- **Red Team & Threat-Led Testing**: MITRE ATT&CK and CAPEC of Adversary-Emulation and Red Team Scoping and Finding-to-Technique Mapping, Council of Registered Ethical Security Testers (CREST) Accreditation Standards, TIBER-EU (Threat Intelligence-Based Ethical Red Teaming) and Bank of England CBEST Intelligence-Led Red Teaming Frameworks, EU Digital Operational Resilience Act (DORA) Threat-Led Penetration Testing (TLPT) Requirements
- **Security Monitoring & Log Management**: NIST SP 800-92 (Guide to Computer Security Log Management), NIST SP 800-137 (Information Security Continuous Monitoring (ISCM)), OMB M-26-14 (Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats), NIST SP 800-53 AU (Audit and Accountability) and SI (System and Information Integrity) Control Families, NIST CSF 2.0 Detect (DE) Function, Security Operations Center Capability Maturity Model (SOC-CMM)
- **Logging & Monitoring Compliance Controls**: CIS Critical Security Controls Control 8 (Audit Log Management), ISO/IEC 27001:2022 Annex A (Logging, Monitoring, and Incident Management Controls), PCI DSS V4.0.1 Requirement 10 (Log and Monitor All Access), HIPAA Security Rule Audit Controls and Security Incident Procedures, SOC 2 Trust Services Criteria CC7 (System Operations), EU NIS2 Directive and DORA Incident Detection and Reporting Timelines
- **Detection Engineering, Log Normalization & Threat Intelligence Ingestion**: MITRE ATT&CK Detection Coverage Mapping, MITRE D3FEND (Defensive Countermeasures Knowledge Graph) and Cyber Analytics Repository (CAR), Sigma Detection Rule Format, Open Cybersecurity Schema Framework (OCSF) and Elastic Common Schema (ECS) for Log Normalization, STIX/TAXII Threat Intelligence Ingestion
- **Incident Response:** NIST CSF 2.0 Respond (RS) and Recover (RC) Functions, NIST SP 800-61 Rev. 3 (Incident Response Recommendations and Considerations of Cybersecurity Risk Management), NIST SP 800-86 (Digital Forensics), ISO/IEC 27035 (Information Technology - Information Security Incident Management), SANS Incident Response Framework, NIST SP 800-53 IR (Incident Response) Control Family, CIS Critical Security Controls Control 17 (Incident Response Management), PCI DSS V4.0.1 Requirement 12.10 (Incident Response), NIST CAISSI/NSA SISC/CISA Key Practices for SI Control Incident Readiness and Response (PP-26-4396; Agentic AI Extension of SP 800-61 Rev. 3 Lifecycle)
- **Incident Reporting & Disclosure:** CISA National Cyber Incident Scoring System (NCISS), CISA Federal Incident Notification Guidelines, Presidential Policy Directive 41 (PPD-41) (US Cyber Incident Coordination), CIRCIA (Cyber Incident Reporting for Critical Infrastructure Act of 2022; Final Rule Still in Development), US Securities and Exchange Commission (SEC) Cybersecurity Disclosure Rules (Form 8-K Item 1.05: Disclosure Within Four Business Days of a Materiality Determination)
- **Data Integrity & Breach Management**: NIST SP 1800-25 (Data Integrity: Identifying and Protecting Assets Against Ransomware and Other Destructive Events), NIST SP 1800-26 (Data Integrity: Detecting and Responding to Ransomware and Other Destructive Events), NIST SP 1800-28 (Data

Confidentiality: Identifying and Protecting Assets Against Data Breaches), NIST SP 1800-29 (Data Confidentiality: Detect, Respond to, and Recover from Data Breaches)

Security Architecture Domains

- **Network Security Architecture**: NIST SP 800-41 Rev. 1 (Guidelines on Firewalls and Firewall Policy), NIST SP 800-125B (Secure Virtual Network Configuration for Virtual Machine System Protection), Network Segmentation & Microsegmentation (Zero Trust Network Access (ZTNA) Principles), Secure Access Service Edge (SASE) & Software-Defined Wide Area Network (SD-WAN) Security Architecture, Network Access Control (NAC) (IEEE 802.1X), Defense-in-Depth & Demilitarized Zone (DMZ) Design
- **DevSecOps & Secure Software Engineering:** NIST SP 800-160 (Systems Security Engineering), DOD DevSecOps Reference Design, NIST SP 800-204 Series (800-204/204A/204B/204C/204D – Microservices & Service-Mesh Security Architecture, Access Control, and DevSecOps Supply Chain Integration), NIST SP 800-218 (Secure Software Development Framework/SSDF), ISO/IEC 15288 (Systems Engineering Life Cycle), ISO/IEC 12207 (Software Life Cycle)
- **Software Supply Chain Security & Policy:** EO 13873 (Securing the Information and Communications Technology and Services Supply Chain), OMB M-26-05 (Adopting a Risk-Based Approach to Software and Hardware Security), Software Supply Chain Risk Management (Software Bill of Materials (SBOM))
- **Application Security Assurance & Threat Modeling:** OWASP Software Assurance Maturity Model (SAMM), OWASP Top 10, STRIDE/PASTA Threat Modeling Methodologies
- **Cloud Security Standards & Guidance:** NIST SP 800-144/145 (Cloud Computing Security/Definition), NIST SP 800-210 (General Access Control Guidance for Cloud Systems), NIST SP 800-201 (NIST Cloud Computing Forensic Reference Architecture), NIST SP 800-209 (Security Guidelines for Storage Infrastructure), Cloud Security Alliance (CSA) Cloud Controls Matrix (CCM)
- **FedRAMP Authorization & Modernization:** OMB M-24-15 (Modernizing Federal Risk and Authorization Management Program (FedRAMP)), FedRAMP & FedRAMP 20x/Consolidated Rules 2026 (CR26, Current Modernization Effort; Replaces Low/Moderate/High with Certification Classes A–D; Mandatory January 1, 2027), FedRAMP Authorization Boundaries
- **Zero Trust & Identity, Credential and Access Management (ICAM):** CISA Zero Trust Maturity Model 2.0, NIST SP 800-63 Rev. 4 (Digital Identity Guidelines), NIST SP 800-205 (Attribute Considerations for Access Control Systems), NIST SP 800-207/800-207A/1800-35 (Zero Trust Architecture, IAM Framework & Implementation Practice Guide), OMB M-22-09 (Federal Zero Trust Strategy)
- **Post-Quantum Cryptography & Quantum Security:** NIST SP 800-208 (Recommendation for Stateful Hash-Based Signature Schemes), NIST IR 8547 (Transition to Post-Quantum Cryptography Standards; Draft), NIST FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA), NSA CNSA 2.0, EO 14412 (Securing the Nation Against Advanced Cryptographic Attacks), EO 14413 (Ushering in the Next Frontier of Quantum Innovation), OMB M-26-15 (Execution of the Migration to Post-Quantum Cryptography)
- **Cryptographic Modules & Algorithm Standards:** NIST Federal Information Processing Standard (FIPS) 140-3 (Security Requirements for Cryptographic Modules), International Organization for Standardization/International Electrotechnical Commission (ISO/IEC) 18033 (Encryption Algorithms) and ISO/IEC 19790 (Security Requirements for Cryptographic Modules)

- **Random Bit Generation & Entropy Standards:** NIST SP 800-90C (Recommendation for Random Bit Generator (RBG) Constructions; RBG1/RBG2/RBG3/RBGC Classes Combining SP 800-90A Rev. 1 Deterministic Random Bit Generator (DRBG) Mechanisms with SP 800-90B Entropy Sources), Supporting FIPS 140-3 Cryptographic Module Validation and Cryptographic Key Generation
- **Key Management & Cryptographic Protocol Standards:** NIST SP 800-57 (Recommendation for Key Management) and NIST SP 800-131A (Transitioning the Use of Cryptographic Algorithms and Key Lengths), Internet Engineering Task Force (IETF) Request for Comments (RFC) Cryptographic Protocol Standards (Transport Layer Security (TLS), Internet Protocol Security (IPsec))
- **Encryption Regulatory & Compliance Safeguards:** PCI DSS Cardholder Data Encryption Requirements, HIPAA Security Rule Encryption Safeguards, EU GDPR Encryption as a Personal Data Safeguard
- **Cryptographic Export Controls:** Wassenaar Arrangement Multilateral Dual-Use Cryptography Export Controls, US Export Administration Regulations (EAR) Category 5 Part 2 Encryption Export Licensing, and International Traffic in Arms Regulations (ITAR) Controls on Defense-Related Cryptographic Items
- **Internet of Things (IoT) Device Security & Product Regulation:** NIST SP 800-213 (IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements), NIST SP 800-213A (IoT Device Cybersecurity Requirement Catalog), NIST SP 1800-36 (Trusted Internet of Things (IoT) Device Network-Layer Onboarding and Lifecycle Management), EU Cyber Resilience Act (CRA, Regulation (EU) 2024/2847 - Cybersecurity Requirements for Products with Digital Elements)
- **Firmware & Platform Integrity:** NIST SP 800-193 (Platform Firmware Resiliency Guidelines), NIST SP 1800-34 (Validating the Integrity of Computing Devices)

Sector-Specific Security & Compliance

- **Unmanned Aircraft Systems (UAS) Operations & Supply Chain Security**: Federal Aviation Administration (FAA) Part 107 (Unmanned Aircraft Systems Operations), National Defense Authorization Act (NDAA) Section 848 & Blue UAS Framework (Cleared UAS Supply Chain/Cybersecurity Vetting), American Security Drone Act
- **UAS Executive Orders & Federal Policy**: EO 14305 (Restoring American Airspace Sovereignty), EO 14307 (Unleashing American Drone Dominance), OMB Memorandum M-26-02 (Ensuring Government Use of Secure Unmanned Aircraft Systems and Supporting United States Producers)
- **Counter-UAS (C-UAS) Authorities, Policy & Detection**: Preventing Emerging Threats Act of 2018 (Codified at 6 U.S.C. § 124n, Protection of Certain Facilities and Assets from Unmanned Aircraft; Amended and Expanded by the SAFER SKIES Act), 49 U.S.C. § 44810 (FAA C-UAS Authority), Department of Defense (DOD) Counter-Small Unmanned Aircraft Systems (C-SUAS) Strategy, SAFER SKIES Act (FY2026 NDAA, P.L. 119-60) & Joint Interagency Task Force 401 (JIATF-401, 10 U.S.C. § 199) Coordination, Department of Homeland Security (DHS)/Department of Justice (DOJ) Interim Final Rule on Counter-UAS Authority of State, Local, Tribal, and Territorial (SLTT) Agencies (July 2026), Radio Frequency (RF)/Global Navigation Satellite System (GNSS) Detection & Mitigation Principles
- **Aviation Sector Security**: Aviation and Transportation Security Act (ATSA) of 2001, Homeland Security Act of 2002, and CISA 2015 as Cross-Cutting Authorities Underpinning TSA and DHS Transportation Systems Sector Cybersecurity Oversight, 14 CFR Part 25 Special Conditions for Aircraft Cybersecurity, Transportation Security Administration (TSA) Joint Emergency Amendment (EA) 23-01 (Aviation Cybersecurity Performance-Based Requirements of Airport &

Aircraft Operator Security Programs), International Civil Aviation Organization (ICAO) Annex 17 (Aviation Security) and Aviation Cybersecurity Strategy, European Union Aviation Safety Agency (EASA) Part-IS (Information Security Regulation), Radio Technical Commission for Aeronautics (RTCA) DO-356A (Airworthiness Security Methods and Considerations), RTCA DO-326A/EUROCAE ED-202A (Airworthiness Security Process Specification), AS9100 (Quality Management Systems of Aviation, Space and Defense Organizations)

- **Space & Satellite Security**: NIST Interagency Report (IR) 8270 (Introduction to Cybersecurity of Commercial Satellite Operations), NIST IR 8323 Rev. 1 (Foundational Positioning, Navigation, and Timing (PNT) Profile: Applying the Cybersecurity Framework for the Responsible Use of PNT Services), NIST IR 8401 (Satellite Ground Segment: Applying the Cybersecurity Framework to Assure Satellite Command and Control), NIST IR 8441 (Cybersecurity Framework Profile for Hybrid Satellite Networks (HSN)), NIST Technical Note (TN) 2272 (Application of the Hybrid Satellite Network Cybersecurity Framework Profile), CISA Recommendations to Space System Operators for Improving Cybersecurity, CISA Space Systems Security and Resilience Landscape: Zero Trust in the Space Environment
- **Water & Wastewater Sector Security (Regulation, Architecture & Standards):** America's Water Infrastructure Act (AWIA) of 2018 (Risk & Resilience Assessments and Emergency Response Plans; Amended Safe Drinking Water Act (SDWA) Section 1433), NIST SP 1800-45 (Cybersecurity of the Water and Wastewater Sector: Build Architecture (Operational Technology Remote Access)), US Environmental Protection Agency (EPA) Water and Wastewater Systems (WWS) Sector Risk Management Agency (SRMA), American Water Works Association (AWWA) G430 (Security Practices for Operation and Management) & J100 (Risk and Resilience Management)
- **Water & Wastewater EPA Assessment Tools & Programs**: EPA Vulnerability Self-Assessment Tool (VSAT), EPA Strengthening Water Infrastructure of Tomorrow (SWIFT) Initiative, EPA Water Cybersecurity Assessment Tool
- **Water & Wastewater OT Cybersecurity & Incident Response Guidance**: EPA Guidance on Improving Cybersecurity at Drinking Water and Wastewater Systems (EPA Office of Water (4608T), EPA 817-B-23-001), EPA Assessing If a Water & Wastewater System Has Operational Technology (Office of Water (4608T), EPA-810-F-23-031), EPA Foundations of OT Cybersecurity: Asset Inventory Guidance for Owners and Operators, EPA Drinking Water and Wastewater Systems Cybersecurity Incident Response Plan Template Instructions
- **Energy Sector Security**: NIST SP 1800-2 (Identity and Access Management for Electric Utilities), NIST SP 1800-7 (Situational Awareness for Electric Utilities), NIST SP 1800-23 (Energy Sector Asset Management: For Electric Utilities, Oil & Gas Industry), NIST SP 1800-32 (Securing Distributed Energy Resources: An Example of Industrial Internet of Things Cybersecurity), EO 14420 (Declaring a National Emergency to Secure the United States Bulk-Power System), EO 13920 (Securing the United States Bulk-Power System), ISO 29001 (Quality Management Systems for the Petroleum, Petrochemical and Natural Gas Industries), Transportation Security Administration (TSA) Security Directive Pipeline-2021 Series (Pipeline Cybersecurity Mitigation Actions, Contingency Planning, and Testing), North American Electric Reliability Corporation (NERC) Critical Infrastructure Protection (CIP) Standards
- **Maritime Sector Security (Statutory & Regulatory Foundations):** Maritime Transportation Security Act (MTSA) of 2002; 33 CFR Subchapter H (Maritime Security); EO 14116 (Amending Regulations Relating to the Safeguarding of Vessels, Harbors, Ports, and Waterfront Facilities)
- **Maritime Cybersecurity Final Rule & USCG Policy:** 33 CFR Part 101 Subpart F (Coast Guard Cybersecurity in the Marine Transportation System Final Rule, 2025 -- Cybersecurity Plans,

Cybersecurity Officer (CYSO), and Penetration Testing Requirements for MTSA-Regulated Vessels, Facilities, and OCS Facilities, Incl. LNG Terminals; Effective July 16, 2025); US Coast Guard Office of Maritime Cybersecurity Policy (CG-MCP; Established August 2026 Under the Director of Inspections and Compliance (CG-5PC) as the Coast Guard's Central Authority for MTS Cybersecurity Policy, Compliance, and Enforcement); 33 CFR Part 6 (Amendments Defining and Requiring Reporting of Cyber Incidents to the USCG, the FBI, and the CISA)

- **Maritime Cyber Incident Reporting & Assessment Guidance**: Navigation and Vessel Inspection Circular (NVIC) 02-24 (Reporting Breaches of Security, Suspicious Activity, Transportation Security Incidents, and Cyber Incidents); NVIC 01-20 (Facility Cyber Risk Assessment Guidance); Maritime Cybersecurity Assessment and Annex Guide (MCAAG)
- **International Maritime Cyber Risk Management & Information Sharing**: International Maritime Organization (IMO) Resolution MSC.428(98) (Maritime Cyber Risk Management in Safety Management Systems); IMO MSC-FAL.1/Circ.3/Rev.2 (Guidelines on Maritime Cyber Risk Management); BIMCO Guidelines on Cyber Security Onboard Ships; Maritime Transportation System Information Sharing and Analysis Center (MTS-ISAC)
- **Industrial Control Systems (ICS) & Operational Technology (OT) Security**: NIST SP 1800-41 (Responding to and Recovering from a Cyber Attack: Cybersecurity of the Manufacturing Sector), NIST SP 800-82 (Guide to Operational Technology (OT) Security), NIST SP 1800-10 (Protecting Information and System Integrity in Industrial Control System Environments: Cybersecurity of the Manufacturing Sector), CISA Cross-Sector Cybersecurity Performance Goals (CPGs), MITRE ATT&CK for ICS, International Electrotechnical Commission (IEC) 62443 (Industrial Automation and Control Systems (IACS) Cybersecurity)
- **5G & Communications Sector Security (NIST, CISA & FCC):** NIST SP 1800-33 (5G Cybersecurity), Cybersecurity and Infrastructure Security Agency (CISA) Communications Sector Critical Infrastructure Guidance, CISA/National Security Agency (NSA)/Office of the Director of National Intelligence (ODNI) 5G Network Slicing: Security Considerations of Design, Deployment, and Maintenance, Federal Communications Commission (FCC) Cybersecurity & Supply Chain Rules (Customer Proprietary Network Information (CPNI) Protection, Secure and Trusted Communications Networks Act)
- **3GPP & GSMA Telecommunications Network Security Standards**: 3rd Generation Partnership Project (3GPP) Technical Specification Group Service and System Aspects Working Group 3 (SA3) Security Architecture (33-Series Specifications), Network Equipment Security Assurance Scheme (NESAS) (Joint 3GPP/Global System of Mobile Communications Association (GSMA) Vendor Security Assurance Framework), GSMA Signaling System 7 (SS7)/Diameter/GPRS Tunneling Protocol (GTP) Interconnect Security Guidelines
- **Banking & Financial Services Security**: Federal Financial Institutions Examination Council (FFIEC) Information Technology Examination Handbook – Information Security Booklet, FDIC Financial Institution Letter (FIL) 10-2014 (ATM and Card Authorization Systems), Office of the Comptroller of the Currency (OCC) Bulletin 2014-13 (Cyber Attacks on Financial Institutions' Automated Teller Machine and Card Authorization Systems: Joint Statement), Cyber Risk Institute (CRI) Profile
- **Automotive Sector Security**: UN Regulation No. 155 (UN R155, Cybersecurity Management System), UN Regulation No. 156 (UN R156, Software Update Management System), ISO/SAE 21434 (Road Vehicles - Cybersecurity Engineering), ISO 24089 (Software Update Engineering), IATF 16949 (Automotive Quality Management Systems)
- **Healthcare Cybersecurity Reference Architectures (NIST SP 1800):** NIST SP 1800-8 (Securing Wireless Infusion Pumps in Healthcare Delivery Organizations), NIST SP 1800-24 (Securing Picture

Archiving and Communication System (PACS): Cybersecurity of the Healthcare Sector), NIST SP 1800-30 (Securing Telehealth Remote Patient Monitoring Ecosystem), NIST SP 1800-1 (Securing Electronic Health Records on Mobile Devices)

- **Healthcare Privacy & Security Standards:** NIST SP 800-66 Rev. 2 (HIPAA Security Rule Implementation Guide), ISO/IEC 27799 (Health Informatics - Information Security Management), HIPAA Security Rule (January 2025 Proposed Update Pending; Final Action Projected Around July 2027), Health Information Technology for Economic and Clinical Health (HITECH) Act of 2009
- **Healthcare Industry Cybersecurity Practices & Frameworks**: HHS 405(D) Health Industry Cybersecurity Practices (HICP), Health Information Trust Alliance (HITRUST) Common Security Framework (CSF)
- **Medical Device Cybersecurity Regulation (FDA):** US Food and Drug Administration (FDA) Cybersecurity in Medical Devices Guidance (Quality Management System Considerations and Content of Premarket Submissions), FDA Quality Management System Regulation (QMSR)/21 CFR Part 820 (Incorporating ISO 13485:2016 By Reference)

Program Management & Enterprise Architecture

- **Program, Project & Portfolio Management**: ISO 21500/21502/21503/21504 (Project, Program and Portfolio Management), ISO 21505 (Governance of Project, Program and Portfolio Management), Project Management Institute (PMI) Project Management Body of Knowledge (PMBOK Guide, 8th Ed.)
- **Process Improvement, Modeling & Quality Management**: Capability Maturity Model Integration (CMMI), CMMI AI Maturity (AIM), Six Sigma/Lean, ISO 9001 (Quality Management Systems), ISO/IEC/IEEE 90003 (Software Engineering - Guidelines for the Application of ISO 9001 to Computer Software), Object Management Group (OMG) Business Process Model and Notation (BPMN) 2.0, OMG Unified Modeling Language (UML), US Government Accountability Office (GAO) Business Process Reengineering Assessment Guide - Version 3
- **Defense Business Systems & Enterprise Architecture**: 10 U.S.C. § 2222 (Defense Business Systems: Business Process Reengineering; Enterprise Architecture; Management), DOD Instruction (DODI) 5000.75 (Business Systems Requirements and Acquisition/Business Capability Acquisition Cycle (BCAC)), Department of War (DoW) Business Process Reengineering Center (BPRC), DOD Architecture Framework (DODAF) 2.02, Business Enterprise Architecture (BEA)